

SIMATS ENGINEERING

ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1410

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01

Total Marks:100

Annexure A

VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

I T.S.HARINI(192521067) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

T.S.HARINI

S.No	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding(20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities(20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most major vulnerabilities with reasonable explanation.	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	

4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well-justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	
5	Report Quality, Evidence, and Presentation(20)	Report is well-structured, professionally written, supported by reliable references, diagrams, tables,	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization,	Report is poorly organized, unsupported, or contains major presentation errors.	
		and a clear risk-rating summary.		evidence, or proper referencing.		
					Total	

Annexure A

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

2. Lowe’s Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe’s retail store in Southfield, Michigan. The compromised wireless connection provided access to the company’s central systems and other retail locations. The attackers attempted to install software intended to capture customers’ credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session-cookie

protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user-security awareness.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable-use policies, and legal consequences.

VULNERABILITY ASSESSMENT REPORT

Selected Case Studies

1. TJX Companies Wireless Network Breach, 2005–2007
2. Firesheep and Public Wi-Fi Session Hijacking, 2010
3. Marriott Wi-Fi Deauthentication Incident, 2014
4. Fake Wi-Fi Networks at the Republican National Convention, 2016
5. Australian Airport and In-Flight Evil-Twin Case, 2024

1. TJX Companies Wireless Network Breach (2005–2007)

2. Objective

To assess wireless-security weaknesses related to encryption, authentication, network segmentation, monitoring, and payment-data protection, and to understand how modern security controls could reduce similar risks.

3. Background

TJX Companies experienced a major payment-card data breach between 2005 and 2007. The incident highlighted weaknesses associated with wireless security, including the use of WEP during a transition to stronger security mechanisms and inadequate controls around access to sensitive network resources.

The incident demonstrates why wireless networks containing or connected to sensitive systems must use strong encryption, authentication, segmentation, monitoring, and access control.

4. Tools Used

- Kali Linux
- Aircrack-ng
- Airodump-ng
- Nmap
- Wireshark

5. Lab Procedure

Step 1: Check wireless interface

```
iwconfig
```

Observation: The available wireless interface is displayed.

Step 2: Enable monitor mode `sudo`

```
airmon-ng start wlan0
```

Observation: The wireless interface changes to a monitor-mode interface, commonly `wlan0mon`.

Step 3: Scan wireless networks `sudo`

```
airodump-ng wlan0mon
```

Observation: Wireless networks are displayed with:

- BSSID
- Channel
- Encryption
- Authentication
- ESSID

Step 4: Identify an authorized lab network

Record the BSSID and channel of your own test access point.

```
sudo airodump-ng --bssid <BSSID> --channel <CHANNEL> -w tjx_lab wlan0mon
```

Step 5: Scan the authorized lab network

After connecting to the lab network:

```
sudo nmap -sV <LAB-IP>
```

Observation: Available services on the authorized test system are identified.

Step 6: Stop monitor mode sudo

```
airmon-ng stop wlan0mon
```

6. Vulnerabilities Identified

Weak Encryption

WEP is obsolete and should not be used to protect sensitive wireless networks.

Weak Authentication

Wireless access should require strong authentication rather than relying on weak shared credentials.

Poor Network Segmentation

Payment systems should be isolated from ordinary wireless clients.

Insufficient Monitoring

Wireless intrusion detection can help identify unauthorized access points and suspicious wireless activity.

Payment Data Exposure

Payment-card information requires strong encryption, access control, monitoring, and protection.

7. Risk Assessment

Vulnerability	Severity
WEP/weak encryption	High
Weak authentication	High
Poor segmentation	Critical
Insufficient monitoring	High
Payment-data exposure	Critical

8. Recommendations

1. Replace WEP with WPA2-Enterprise or WPA3-Enterprise.
2. Implement 802.1X authentication.
3. Use centralized RADIUS authentication.
4. Separate guest, corporate, and payment networks.
5. Deploy wireless IDS/IPS.
6. Encrypt sensitive payment information.
7. Apply PCI DSS requirements.
8. Monitor access to cardholder-data environments.
9. Perform regular vulnerability assessments.

9. Conclusion

The TJX incident demonstrates that obsolete wireless encryption and inadequate network controls can contribute to serious data breaches. Strong WPA2/WPA3 security, enterprise authentication, network segmentation, monitoring, and PCI DSS controls can significantly reduce the risk of unauthorized access to payment systems.

10. Evidence

Attach screenshots of:

- iwconfig
- airmon-ng
- airodump-ng
- nmap
- Wireshark, if used

```
(kali@kali)-[~]
$ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

(kali@kali)-[~]
$ sudo airmon-ng start wlan0
[sudo] password for kali:

Found 1 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
503 NetworkManager

Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces

(kali@kali)-[~]
$ sudo airodump-ng wlan0mon
sudo: airodump-ng: command not found

(kali@kali)-[~]
$ sudo airmon-ng stop wlan0mon

Requested device "wlan0mon" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces
```

2. Firesheep and Public Wi-Fi Session Hijacking (2010)

2. Objective

To assess the security risks associated with public Wi-Fi, insecure HTTP communication, session cookies, HTTPS enforcement, HSTS, VPN usage, client isolation, and user awareness.

3. Background

Firesheep demonstrated the risks of transmitting session information over unencrypted HTTP on shared wireless networks. If a website protected only the login process but later transmitted session information over HTTP, an attacker on the same network could potentially obtain sensitive session information.

This assessment reproduces the security concepts using an authorized local laboratory web application.

4. Tools Used

- Kali Linux
- Nmap
- cURL
- Wireshark

5. Lab Procedure

Step 1: Check IP address ip

addr

Step 2: Identify the authorized lab network ip

route

Step 3: Discover authorized lab systems sudo

nmap -sn <LAB-NETWORK>/24

Step 4: Identify web services sudo

nmap -sV -p 80,443 <LAB-IP>

Step 5: Check HTTP headers

curl -I http://<LAB-IP> Look

for:

- Set-Cookie
- Location
- Security headers

Step 6: Check HTTPS

curl -k -I https://<LAB-IP>

Step 7: Check HSTS

curl -I https://<LAB-IP> | grep -i strict

Step 8: Open Wireshark sudo

wireshark

Useful filters:

http

and:

tls

6. Vulnerabilities Identified

Open Wireless Network

Public open Wi-Fi provides limited protection against other users on the same network.

HTTP Communication

HTTP traffic is not encrypted and can expose information to network observers.

Insecure Cookies

Session cookies should be protected with appropriate security attributes.

Missing HSTS

HSTS helps ensure that browsers use HTTPS rather than insecure HTTP.

Lack of User Awareness

Users may connect to public networks without understanding their security risks.

7. Risk Assessment

Vulnerability	Severity
Open Wi-Fi	High
HTTP communication	High
Weak session protection	Critical
Missing HSTS	Medium
User awareness	Medium

8. Recommendations

1. Use HTTPS for the complete website session.
2. Enable HSTS.
3. Use Secure cookies.
4. Use HttpOnly cookies.
5. Configure appropriate SameSite settings.
6. Use VPNs on untrusted networks.
7. Enable wireless client isolation.
8. Educate users about public Wi-Fi security.

9. Conclusion

The Firesheep incident demonstrated that protecting only the login page is insufficient. Complete HTTPS enforcement, secure session cookies, HSTS, wireless client isolation, VPN usage, and user awareness are important protections against session-related risks on public networks.

10. Evidence

Attach:

- IP configuration screenshot
- Nmap screenshot
- HTTP `curl` screenshot
- HTTPS `curl` screenshot
- Wireshark HTTP/TLS screenshot

```

(kali@kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 86089sec preferred_lft 86089sec
    inet6 fd17:625c:f037:2:c895:be2a:58f0:bb0e/64 scope global dynamic noprefixroute
        valid_lft 86090sec preferred_lft 14090sec
    inet6 fe80::66cb:297d:718a:d5c7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ sudo nmap -sV <LAB-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ curl -I http://<LAB-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ curl -k -I https://<LAB-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ sudo wireshark
sudo: wireshark: command not found

(kali@kali)-[~]
$ http
Command 'http' not found, but can be installed with:
sudo apt install httpie
Do you want to install it? (N/y)n

(kali@kali)-[~]
$ tls
Command 'tls' not found, but there are 19 similar ones.

```

3. Marriott Wi-Fi Deauthentication Incident (2014)

2. Objective

To analyze the security risks associated with IEEE 802.11 deauthentication frames and evaluate the importance of Protected Management Frames, wireless intrusion detection, WPA3, and wireless security policies.

3. Background

The Marriott incident involved the use of equipment to send Wi-Fi deauthentication messages that affected guests' wireless connectivity. The case highlighted risks associated with wireless management frames and the importance of protecting wireless availability.

4. Tools Used

- Kali Linux
- Aircrack-ng
- Airodump-ng
- Wireshark

5. Lab Procedure

Step 1: Check adapter iwconfig

Step 2: Enable monitor mode sudo

airmon-ng start wlan0

Step 3: Scan the authorized lab environment sudo

airodump-ng wlan0mon

Step 4: Capture the authorized test AP sudo airodump-ng --bssid <BSSID> --channel

<CHANNEL> -w marriott_lab wlan0mon

Step 5: Open capture wireshark

marriott_lab-01.cap

Step 6: Find deauthentication frames

Use the Wireshark filter:

wlan.fc.type_subtype == 0x0c

The captured packets can be examined for:

- Source
- Destination
- Reason code
- Frame type

Step 7: Stop monitor mode sudo

airmon-ng stop wlan0mon

6. Vulnerabilities Identified

Unprotected Management Frames

Management frames may be abused when adequate protection is not enabled.

Availability Risk

Unauthorized management frames can cause legitimate clients to disconnect.

Insufficient Monitoring

Wireless IDS/IPS can detect abnormal wireless management-frame behavior.

7. Risk Assessment

Vulnerability	Severity
Unprotected management frames	High
Deauthentication abuse	High
Availability disruption	High
Insufficient monitoring	Medium

8. Recommendations

1. Enable Protected Management Frames (PMF).
2. Use WPA3 where supported.
3. Deploy wireless IDS/IPS.
4. Monitor abnormal deauthentication activity.
5. Maintain wireless acceptable-use policies.
6. Investigate repeated unexpected disconnections.
7. Keep wireless infrastructure firmware updated.

9. Legal and Policy Considerations

Wireless interference or intentional disruption of networks without authorization can violate organizational policies and applicable laws. Security testing must therefore be conducted only in an authorized laboratory.

10. Conclusion

The Marriott incident demonstrates that wireless management frames can create availability risks when they are insufficiently protected. PMF, WPA3, wireless monitoring, and appropriate security policies can reduce the likelihood and impact of unauthorized wireless disruption.

11. Evidence Attach:

- `iwconfig`
- `airmon-ng`
- `airodump-ng`
- Wireshark deauthentication-frame screenshot

```

(kali@kali)-[~]
$ sudo airmon-ng start wlan0
Found 1 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
503 NetworkManager

Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces

(kali@kali)-[~]
$ sudo airodump-ng wlan0mon
sudo: airodump-ng: command not found

(kali@kali)-[~]
$ sudo airodump-ng --bssid <BSSID> --channel <CHANNEL> -w marriott wlan0mon
zsh: no such file or directory: BSSID

(kali@kali)-[~]
$ wireshark marriott-01.cap
wlan.fc.type_subtype = 0x0c
^C

(kali@kali)-[~]
$ wlan.fc.type_subtype == 0x0c
wlan.fc.type_subtype: command not found

(kali@kali)-[~]
$ sudo airmon-ng stop wlan0mon
usage: airmon-ng <start|stop|check> <interface> [channel or frequency]

```

4. Fake Wi-Fi Networks at the Republican National Convention (2016)

2. Objective

To assess the risks associated with fake or rogue wireless networks and evaluate SSID trust, automatic reconnection, captive portals, certificate validation, VPN usage, and user awareness.

3. Background

A security experiment during the 2016 Republican National Convention demonstrated how users could connect to fake open wireless networks. The scenario illustrates the risks of trusting wireless network names without verifying the legitimacy of the access point.

4. Tools Used

- Kali Linux
- Airodump-ng
- Airmon-ng
- Kismet
- Wireshark
- NetworkManager

5. Lab Procedure

Step 1: Enable monitor mode sudo

```
airmon-ng start wlan0
```

Step 2: Scan for wireless networks

```
sudo  
airodump-ng wlan0mon
```

Observe:

- SSID
- BSSID
- Channel
- Encryption
- Signal strength

Step 3: Perform detailed wireless scan

```
sudo  
iw dev wlan0mon scan
```

Step 4: Check saved wireless networks

```
nmcli  
connection show
```

This helps assess automatic reconnection risks.

Step 5: Use Kismet

```
sudo  
kismet
```

Kismet can be used to monitor wireless networks and identify suspicious or unauthorized access points.

Step 6: Capture an authorized lab network

```
sudo airodump-ng -w evil_twin_lab wlan0mon
```

Step 7: Stop monitor mode

```
sudo  
airmon-ng stop wlan0mon
```

6. Vulnerabilities Identified

SSID Trust

Users may assume that a familiar SSID belongs to the legitimate organization.

Automatic Reconnection

Devices may automatically reconnect to previously saved networks.

Open Wi-Fi

Open networks provide limited assurance of network authenticity.

Rogue Access Points

Unauthorized APs can imitate legitimate SSIDs.

User Awareness

Users may not verify wireless network details before connecting.

7. Risk Assessment

Vulnerability	Severity
Rogue AP	High
Open Wi-Fi	High
Automatic reconnection	High
Fake captive portal	High
User awareness	Medium

8. Recommendations

1. Deploy wireless IDS/IPS.
2. Use WPA2/WPA3-Enterprise.
3. Disable unnecessary open networks.
4. Encourage VPN use on untrusted networks.
5. Disable automatic connections to unknown networks.
6. Verify certificates.
7. Educate users about evil-twin attacks.
8. Monitor duplicate SSIDs and unauthorized BSSIDs.

9. Conclusion

The fake Wi-Fi demonstration shows that users can easily trust familiar-looking SSIDs. Organizations hosting large events should implement rogue-AP detection, strong wireless authentication, network monitoring, VPN protection, and security-awareness training.

10. Evidence

Attach:

- airmon-ng screenshot
- airodump-ng screenshot
- Duplicate SSID observation
- Kismet screenshot
- nmcli connection show screenshot

```
(kali@kali)-[~]
$ sudo airmon-ng start wlan0

Found 1 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
503 NetworkManager

Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces

(kali@kali)-[~]
$ sudo airmon-ng wlan0mon

usage: airmon-ng <start|stop|check> <interface> [channel or frequency]

(kali@kali)-[~]
$ sudo iw wlan0mon scan
Usage: iw [options] command
Options:
  --debug          enable netlink debugging
  --version        show version (6.17)
Commands:
  dev <devname> ap stop
                  Stop AP functionality

  dev <devname> ap start <SSID> <SSID> <freq> [NOHT|HT20|HT40+|HT40-|5MHz|10MHz|80MHz|160MHz|320MHz] [punct <bitmap>]
                  tail in hexadecimal]] [inactivity-time <inactivity time in seconds>] [key0:abcde d:1:6162636465]
  dev <devname> ap start <SSID> <control freq> [5120|20400|80180+80180|1601320] [<center1_freq> [<center2_freq>]] [punct
  il <beacon tail in hexadecimal>] [inactivity-time <inactivity time in seconds>] [key0:abcde d:1:6162636465]
                  Start an AP. Note that this usually requires hostapd or similar.

  phy <phyname> coalesce show
                  Show coalesce status.

  phy <phyname> coalesce disable
                  Disable coalesce.

  phy <phyname> coalesce enable <config-file>
                  Enable coalesce with given configuration.
                  The configuration file contains coalesce rules:
                  delay=<delay>
                  condition=<conditions>
```

```
(kali@kali)-[~]
$ nmcli connection show
NAME                UUID                                TYPE      DEVICE
Wired connection 1  ed8f7123-82c5-30b3-ae73-19b1ca482ecb ethernet  eth0
lo                  f41c945d-88bd-4c29-89ba-9ed04994e495 loopback   lo

(kali@kali)-[~]
$ sudo kismet
INFO: Including sub-config file: /etc/kismet/kismet_httpd.conf
INFO: Including sub-config file: /etc/kismet/kismet_memory.conf
INFO: Including sub-config file: /etc/kismet/kismet_alerts.conf
INFO: Including sub-config file: /etc/kismet/kismet_80211.conf
INFO: Including sub-config file: /etc/kismet/kismet_logging.conf
INFO: Including sub-config file: /etc/kismet/kismet_filter.conf
INFO: Including sub-config file: /etc/kismet/kismet_uav.conf
INFO: Loading config override file '/etc/kismet/kismet_package.conf'
INFO: Optional sub-config file not present: /etc/kismet/kismet_package.conf
INFO: Loading config override file '/etc/kismet/kismet_site.conf'
INFO: Optional sub-config file not present: /etc/kismet/kismet_site.conf
INFO: Local config and cache directory '/root/.kismet/' does not exist;
      creating it.
KISMET - Point your browser to http://localhost:2501 (or the address of this system) for the Kismet UI
INFO: Registered PHY handler 'RFSSENSOR' as ID 1
INFO: Registered PHY handler 'Z-Wave' as ID 2
INFO: Registered PHY handler 'Bluetooth' as ID 3
DEBUG: reserve_fields home id 542 app id 543
INFO: Registered PHY handler 'UAV' as ID 4
INFO: Registered PHY handler 'MrfMouseJack' as ID 5
ERROR: Tried to re-register duplicate alert FLIPPERZERO
INFO: Registered PHY handler 'BTLE' as ID 6
INFO: Registered PHY handler 'METER' as ID 7
INFO: Indexing ADSB ICAO db
INFO: Completed indexing ADSB ICAO db, 341068 lines 6822 indexes
INFO: Registered PHY handler 'ADSB' as ID 8
INFO: Registered PHY handler '802.15.4' as ID 9
INFO: Registered PHY handler 'RADIATION' as ID 10
ERROR: Error reading config file '/root/.kismet/kismet_httpd.conf': No
      such file or directory
LOCAL: This is the first time Kismet has been run as this user. You will
```

5. Australian Airport and In-Flight Evil-Twin Wi-Fi Case (2024)

2. Objective

To assess the risks associated with fake Wi-Fi access points at airports and other public locations, including SSID impersonation, automatic connection, captive portals, certificate validation, passenger-data exposure, rogue-AP detection, and user verification.

3. Background

In 2024, Australian authorities charged an individual in connection with alleged fake Wi-Fi access points that imitated legitimate networks at airports and other locations. The case demonstrates the risks faced by users who connect to Wi-Fi networks based only on familiar network names.

4. Tools Used

- Kali Linux
- Airmon-ng
- Airodump-ng
- Nmap
- Wireshark
- OpenSSL
- NetworkManager

5. Lab Procedure

Step 1: Check wireless adapter `iwconfig`

Step 2: Enable monitor mode `sudo`

`airmon-ng start wlan0`

Step 3: Scan wireless networks `sudo`

`airodump-ng wlan0mon`

Observe:

- SSID
- BSSID
- Channel
- Encryption
- Signal strength

Step 4: Detailed wireless scan `sudo`

`iw dev wlan0mon scan`

Step 5: Check saved Wi-Fi networks nmcli

connection show

Step 6: Check current network

nmcli device status

Step 7: Scan an authorized lab web portal sudo

nmap -sV -p 80,443 <LAB-IP>

Step 8: Check HTTPS headers curl

-I https://<LAB-IP>

Step 9: Inspect TLS certificate openssl

s_client -connect <LAB-IP>:443

Inspect the certificate information and verification result.

Step 10: Analyze wireless traffic wireshark

Useful filter:

wlan.fc.type_subtype == 0x08

This displays beacon frames, which can help analyze advertised SSIDs.

Step 11: Stop monitor mode sudo

airmon-ng stop wlan0mon

6. Vulnerabilities Identified**SSID Impersonation**

Attackers may advertise an SSID that appears similar or identical to a legitimate airport Wi-Fi network.

Automatic Connection

Previously saved wireless profiles can cause devices to connect without sufficient user verification.

Captive Portal Risk

A fraudulent portal could attempt to collect credentials or personal information.

Certificate Validation

Ignoring HTTPS certificate warnings can expose users to additional risks.

Rogue AP Detection

Organizations require monitoring systems to identify unauthorized access points.

7. Risk Assessment

Vulnerability	Severity
SSID impersonation	High
Rogue AP	High
Automatic connection	High
Fake captive portal	High
Certificate validation failure	High
Passenger-data exposure	High

8. Recommendations

1. Deploy wireless IDS/IPS.
2. Monitor for duplicate SSIDs.
3. Use WPA2/WPA3-Enterprise for staff networks.
4. Provide clearly documented official Wi-Fi information.
5. Encourage users to disable automatic connection to unknown networks.
6. Enforce HTTPS on captive portals.
7. Use valid TLS certificates.
8. Educate passengers and employees about evil-twin attacks.
9. Use VPN protection on untrusted networks.
10. Establish staff procedures for reporting suspicious Wi-Fi.

9. Conclusion

The Australian airport case demonstrates that fake Wi-Fi networks can exploit user trust rather than directly attacking a legitimate wireless infrastructure. Strong wireless monitoring, user verification, secure captive portals, HTTPS, certificate validation, and security awareness can significantly reduce the risk.

10. Evidence

Attach:

- iwconfig
- airmon-ng
- airodump-ng
- iw scan
- nmcli
- Nmap scan
- cURL HTTPS headers
- OpenSSL certificate information
- Wireshark beacon-frame analysis

```
(kali@kali)-[~]
$ sudo airmon-ng start wlan0

Found 1 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
503 NetworkManager

Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces

(kali@kali)-[~]
$ sudo iw dev wlan0mon scan
command failed: No such device (-19)

(kali@kali)-[~]
$ nmcli device status
DEVICE  TYPE      STATE      CONNECTION
eth0    ethernet  connected  Wired connection 1
lo      loopback  connected (externally)  lo

(kali@kali)-[~]
$ curl -I https://<LAB-IP>
zsh: parse error near `\\n'

(kali@kali)-[~]
$ openssl s_client -connect <LAB-IP>:443
zsh: no such file or directory: LAB-IP

(kali@kali)-[~]
$ sudo airmon-ng stop wlan0mon

Requested device "wlan0mon" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces
```